

Applicability Compliance

1. Requirement 1 focuses on installing and maintaining Network Security Controls (NSCs) to protect the Cardholder Data Environment (CDE)
 - 1.1. **Accurate Diagrams:** Maintain up-to-date network diagrams showing all connections to the CDE and data-flow diagrams showing how account data moves across systems.
 - 1.2. **Restricted Services:** Identify and approve all allowed services, protocols, and ports with a defined business need. Implement additional security features for any insecure protocols that must be used.
 - 1.3. **Secure Configuration Files:** Protect configuration files from unauthorized access and ensure they match active network settings.
 - 1.4. **Traffic Control:** Restrict inbound and outbound CDE traffic to only what is strictly necessary, specifically denying all other traffic.
 - 1.5. **Trusted vs. Untrusted Networks:** Implement NSCs between trusted and untrusted networks, ensuring that system components storing cardholder data are never directly accessible from untrusted networks.
 - 1.6. **Internal IP Protection:** Limit the disclosure of internal IP addresses and routing information to authorized parties only.
2. Requirement 2 focuses on applying secure configurations to all system components to protect against exploits using vendor defaults or insecure settings.
 - 2.1. **Hardening Standards:** Develop and maintain configuration standards for all system components that address known vulnerabilities and align with industry-accepted hardening standards (such as CIS or NIST).
 - 2.2. **Vendor Defaults:** Change all vendor-supplied default passwords for accounts in use, and remove or disable any default accounts that are not needed.
 - 2.3. **Function Isolation:** Configure systems to have only one primary function per component (e.g., separate web servers from databases) or isolate functions requiring different security levels.
 - 2.4. **Minimal Services:** Enable only necessary services, protocols, and daemons required for business; disable or remove all unnecessary functionality.
 - 2.5. **Insecure Protocols:** Document the business justification for any insecure services or protocols used and implement additional security features to mitigate the associated risks.
 - 2.6. **Security Parameters:** Configure all system security parameters according to standards to prevent misuse.
 - 2.7. **Encrypted Administration:** Use strong cryptography to encrypt all non-console (remote) administrative access.
3. Requirement 3 focuses on protecting stored account data through technical and procedural safeguards.
 - 3.1. **Storage Prohibitions:** Ensure Sensitive Authentication Data (SAD)—including full track data, card verification codes (CVV), and PINs/PIN blocks—is never stored after a transaction is authorised.
 - 3.2. **PAN Masking:** Mask the Primary Account Number (PAN) when displayed; the bank identification number (BIN) and the last four digits are the maximum number of digits shown unless a role has a documented business need to see more. doc needed
 - 3.3. **PAN Unreadability:** Render PAN unreadable everywhere it is stored (including backups, audit logs, and troubleshooting logs) using strong cryptography, keyed cryptographic hashes of the entire PAN, truncation, or index tokens. doc needed

- 3.4. **Cryptographic Architecture: (Service Providers only)** Maintain a documented description of the cryptographic architecture, including details of all algorithms, protocols, and keys used. doc needed
4. Requirement 4 focuses on protecting cardholder data with strong cryptography when it is transmitted over open, public networks.
 - 4.1. **Public Network Encryption:** Encrypt the Primary Account Number (PAN) with strong cryptography and secure protocols whenever it is transmitted over open, public networks. This includes **5 specific technology types:** 1) The Internet, 2) Wi-Fi, 3) Bluetooth, 4) Cellular, and 5) Satellite communications. doc needed (for policy definitions)
 - 4.2. **Trust Verification:** Configure all systems to reject any keys or certificates that cannot be verified as trusted.
 - 4.3. **Messaging Restrictions:** Ensure PAN is never sent in cleartext via end-user messaging technologies, such as email, SMS, or instant messaging.
5. Requirement 5 focuses on protecting all systems and networks from malicious software and phishing. Need discussion
 - 5.1. **Anti-Malware Deployment:** Deploy anti-malware solutions on all system components, except those determined to not be at risk via a periodic evaluation.
 - 5.2. **Malware Capability:** Ensure the solution detects all known types of malwares and is configured to remove, block, or contain them.
 - 5.3. **Automatic Updates:** Configure the solution to stay current via automatic updates without requiring user intervention.
 - 5.4. **Removable Media Security:** Configure the solution to automatically scan all removable electronic media (such as USB drives) immediately upon being inserted, connected, or logically mounted.
 - 5.5. **Audit Logging:** Enable anti-malware logs and retain them for at least 12 months, ensuring the most recent three months are immediately available for analysis.
 - 5.6. **User Restrictions:** Implement technical controls so users cannot disable or alter anti-malware mechanisms unless specifically authorized by management for a limited period on a case-by-case basis. doc needed
 - 5.7. **Phishing Protections:** Implement automated technical mechanisms to detect and protect personnel against phishing attacks.
6. Requirement 6 focuses on the secure development and maintenance of systems and software.
 - 6.1. **Secure Development Process:** Develop bespoke and custom software based on industry standards and incorporate information security at every stage of the software development lifecycle (SLC). doc needed
 - 6.2. **Pre-release Code Reviews:** Review all bespoke and custom code prior to production release. If manual reviews are used, they must be performed by someone other than the author and approved by management. doc needed
 - 6.3. **Vulnerability Identification:** Identify new security vulnerabilities using industry-recognised sources and assign a risk ranking (e.g., high or critical) to each. doc needed
 - 6.4. **Security Patching:** Install applicable security patches for critical vulnerabilities within one month of release. All other patches must be installed within a timeframe defined by the entity's targeted risk analysis. doc needed

- 6.5. **Web Application Protection:** Protect public-facing web applications from attacks using either an automated technical solution (like a WAF) or by performing manual/automated vulnerability assessments at least once every 12 months.
- 6.6. **Environment Separation:** Maintain strict separation between pre-production (development/test) and production environments, enforced by access controls. doc needed
- 6.7. **Data Restrictions:** Prohibit the use of "live" Primary Account Numbers (PANs) in pre-production environments unless they are part of the CDE and fully protected. doc needed
- 6.8. **Clean-up Procedures:** Remove all test data and test accounts from system components before they become active in production. doc needed
- 7. Requirement 7 focuses on restricting access to system components and cardholder data based on a business "need to know."
 - 7.1. **Defined Access Model:** Define an access control model for all system components based on job classification and function, incorporating "need to know" and the least privileges necessary for each role. doc needed
 - 7.2. **Privilege Assignment:** Assign access to users, including privileged users, based strictly on their job function and the minimum scope required.
 - 7.3. **Application/System Account Management:** Manage application and system accounts (service accounts) based on least privilege, limiting them to only the specific systems or processes that require their use. doc needed
 - 7.4. **Restricted Data Queries:** Restrict user access to query cardholder data repositories to programmatic methods (like applications) only; direct or ad hoc query access is prohibited except for authorized administrators. doc needed
 - 7.5. **Access Control System Deployment:** Implement an automated access control system(s) that covers all system components to manage and restrict access.
 - 7.6. **System Configuration:** Configure the access control system to enforce permissions based on job classification and function.
 - 7.7. **Default "Deny All":** Configure access control systems with a default setting of "deny all," ensuring no access is permitted unless specifically allowed by a rule.
- 8. Requirement 8 focuses on identifying all users and authenticating access to system components to ensure actions are attributable to known individuals.
 - 8.1. **Unique Identification:** Assign a unique ID to every user before allowing access to system components or cardholder data.
 - 8.2. **Immediate Revocation:** Immediately revoke access for any terminated users and return or deactivate their physical authentication factors.
 - 8.3. **Inactive Account Cleanup:** Remove or disable inactive user accounts within 90 days.
 - 8.4. **Idle Session Timeouts:** Require users to re-authenticate if a session has been idle for more than 15 minutes.
 - 8.5. **Strong Authentication Factors:** Use at least one factor—something you know (password), have (token/smart card), or are (biometrics)—for all user access.
 - 8.6. **Authentication Security:** Render all authentication factors unreadable during transmission and storage using strong cryptography.
 - 8.7. **Temporary Password Management:** Ensure passwords for first-time use or reset are unique and forced to be changed immediately upon first use.
 - 8.8. **Password Complexity:** Enforce a minimum length of 12 characters (or 8 if the system is technically limited) and require both numeric and alphabetic characters.
 - 8.9. **Password History:** Prohibit users from submitting a new password that is the same as any of the last four passwords used.

- 8.10. **Multi-Factor Authentication (MFA):** Implement MFA for all non-console access into the CDE and all remote access originating from outside the network.
- 8.11. **Application Account Management:** Manage application and system accounts to prevent interactive use unless needed for an exceptional, documented circumstance approved by management. doc needed
- 8.12. **Hard-Coding Prohibition:** Ensure passwords for application/system accounts are not hard-coded in scripts, configuration files, or source code.
- 9. Requirement 9 focuses on restricting physical access to cardholder data through facility controls, personnel management, and media security.
 - 9.1. None
- 10. Requirement 10 focuses on logging and monitoring all access to system components and cardholder data.
 - 10.1. **Comprehensive Logging:** Enable audit logs for all system components to capture 7 specific event types: 1) user access to cardholder data, 2) administrative actions, 3) access to logs, 4) invalid access attempts, 5) changes to authentication credentials, 6) pausing/restarting of logs, and 7) creation/deletion of system-level objects.
 - 10.2. **Log Entry Details:** Ensure every log entry includes 6 specific elements: 1) user ID, 2) type of event, 3) date and time, 4) success or failure, 5) origination point, and 6) identity of the affected system or data.
 - 10.3. **Access and Protection:** Limit log read access to those with a business need, protect logs from unauthorized modification, and promptly back up logs to a secure, centralized log server.
 - 10.4. **Anomaly Response:** Address all exceptions and anomalies identified during the log review process.
 - 10.5. **Time Synchronization:** Synchronize all system clocks using time-synchronization technology (like NTP) to ensure accurate log timelines.
 - 10.6. **Critical Control Failures:** Implement processes to promptly detect and alert on failures of critical security control systems (e.g., firewalls, logs, FIM).
- 11. Requirement 11 focuses on regular security testing to verify that your system defences remain effective against evolving threats.
 - 11.1. **Internal Vulnerability Scans:** Perform internal vulnerability scans at least once every three months and resolve all high-risk or critical vulnerabilities. doc needed
 - 11.2. **Authenticated Internal Scanning:** Perform internal scans via authenticated scanning; document any systems unable to accept credentials. doc needed
 - 11.3. **Scans after Significant Changes:** Perform internal and external scans after any significant change; external scans must resolve vulnerabilities scored 4.0 or higher by the CVSS. doc needed
 - 11.4. **Segmentation Validation:** Verify the effectiveness of all segmentation and scope-reduction controls at least once every 12 months (or every six months for service providers). doc needed
 - 11.5. **Payment Page Integrity:** Implement a mechanism to detect and alert on unauthorised changes to HTTP headers and script contents on payment pages as received by the consumer browser; checks must occur at least weekly or at a frequency defined in a Targeted Risk Analysis (TRA). doc needed

12. Requirement 12 focuses on supporting information security through formal organizational policies and programs.
 - 12.1. **Cipher and Protocol Inventory:** Maintain an inventory of all cryptographic cipher suites and protocols in use and review them at least once every 12 months. doc needed
 - 12.2. **System Inventory:** Maintain a current inventory of all in-scope system components, including their specific function or use. doc needed
 - 12.3. **Incident Response Plan:** Maintain a formal plan (including roles, containment, and recovery) and test it at least once every 12 months. doc needed